

UNIVERSIDAD MAYOR DE SAN ANDRÉS

Carrera de Informática – Seguridad de la Información



Proyecto: Evaluación de seguridad de Módulos de Autenticación Web - Escudo Pet Spa

Nombre del informe: Informe de Pentesting – Evaluación de seguridad y funcionalidad de módulos de autenticación en entorno local

Materia: Taller Técnico Superior

Analista de seguridad: Limachi Tapia Guillermo

Estudiante revisado: Aruquipa Ururi Luz Edely

Fecha: 18/05/26

Clasificación del documento: Académico / Confidencial

Análisis hipotético y planificación ofensiva

1. RESUMEN EJECUTIVO

El presente informe documenta el análisis de superficie de ataque, identificación teórica de vulnerabilidades y simulación de vectores de ataque sobre el sistema "Pet Spa", considerando los módulos correspondientes a Administrador, Recepción, Groomer y Cliente.

Debido a limitaciones del entorno, las evaluaciones fueron realizadas mediante análisis audiovisual del sistema y revisión conceptual de seguridad ofensiva.

2. OBJETIVOS

2.1 Objetivo General

Ejemplo:

Evaluar teóricamente la seguridad del sistema Pet Spa mediante técnicas de reconocimiento, análisis de autenticación, revisión de controles RBAC (Control de Acceso Basado en Roles) y simulación de pruebas de intrusión.

2.2 Objetivos Específicos

- Analizar el sistema de autenticación.
- Evaluar posibles debilidades JWT (JSON Web Token).
- Identificar riesgos de escalación de privilegios.
- Evaluar políticas de contraseñas.
- Detectar malas prácticas visibles.
- Proponer medidas de mitigación.

3. ALCANCE

Aquí defines qué módulos se analizaron.

Ejemplo:

Módulos Evaluados

- Login
- Registro de clientes
- Panel Administrador
- Recepción
- Groomer
- Cliente
- Gestión de usuarios

- Reportes
- Reservas
- Historiales

LIMITACIONES DEL ENTORNO

El análisis realizado corresponde a una evaluación teórica basada en material audiovisual proporcionado por terceros. No se contó con acceso directo al entorno funcional, servidor, base de datos, APIs ni tráfico real de red, por lo que no fue posible ejecutar explotación activa ni validaciones prácticas de vulnerabilidades.

4. METODOLOGÍA

Metodología Utilizada

- Reconocimiento pasivo
- Análisis visual de autenticación
- Evaluación OWASP Top 10
- Simulación de vectores de ataque
- Evaluación RBAC
- Análisis de malas prácticas

5. RECONOCIMIENTO Y SUPERFICIE DE ATAQUE

Hallazgo	Observación	Superficie de ataque	Vulnerabilidad teórica	Pruebas hipotéticas	Simulación de ataque	Riesgo	Impacto	Severidad	Mitigación	Mejora recomendada
Creación ilimitada de cuentas de clientes	El sistema permite crear cuentas libremente mediante correo/contraseña o Google sin restricciones visibles.	Registro, formularios públicos, BD, API	Registro masivo automatizado y agotamiento de recursos	Bots, flood de registros, correos temporales	Un atacante podría crear miles de cuentas falsas para saturar la BD y degradar el servicio.	Saturación de recursos y denegación parcial de servicio	Alto	Alta	CAPTCHA, rate limiting, controles anti-bot	Implementar reCAPTCHA y límites por IP/dispositivo
Ausencia de CAPTCHA en autenticación	El login no implementa CAPTCHA y solo utiliza bloqueo tras 5 intentos fallidos.	Login, autenticación, sesiones	Fuerza bruta y credential stuffing	Automatización de intentos, rotación IP, enumeración de usuarios	Un atacante podría probar múltiples credenciales automatizadamente hasta obtener acceso válido.	Acceso no autorizado y robo de cuentas	Alto	Alta	CAPTCHA adaptativo, MFA y monitoreo	Activar CAPTCHA dinámico y detección de comportamiento sospechoso
Ausencia de validación estricta en formularios	Los formularios permiten ingresar información arbitraria sin controles visibles estrictos.	Formularios, creación de usuarios, panel administrativo	Ingreso de datos inválidos o payloads maliciosos	XSS, inputs extensos, caracteres especiales	Un atacante podría introducir datos maliciosos afectando integridad y estabilidad.	Corrupción de datos y posibles ataques XSS	Medio-Alto	Media-Alta	Sanitización y validación backend/frontend	Implementar validaciones tipadas y restricciones de formato
Ausencia de MFA en Groomers y clientes	Solo administrador utiliza 2FA; Groomers y clientes no poseen MFA.	Login Groomer, Login Cliente, sesiones	Mayor exposición a robo de credenciales	Credential stuffing, phishing, robo de sesión	Un atacante podría ingresar directamente usando credenciales comprometidas.	Compromiso de cuentas y acceso indebido	Alto	Alta	MFA obligatorio y alertas de acceso	Implementar MFA obligatorio en perfiles sensibles
Bloqueo temporal insuficiente	El bloqueo dura 15 minutos pero no existen controles contra rotación IP ni automatización avanzada.	Login, autenticación	Bypass del bloqueo mediante ataques distribuidos	Rotación de IPs, bots paralelos	Un atacante podría continuar ataques distribuidos evitando el bloqueo temporal.	Persistencia de ataques automatizados	Alto	Alta	Fingerprinting, CAPTCHA progresivo y rate limiting	Protección basada en reputación IP y análisis de comportamiento
Ausencia visible de controles anti SQL Injection	No se observan validaciones visibles contra SQL Injection.	Formularios, backend, BD	Posible explotación SQLi	Payloads SQL, bypass login, enumeración de tablas	Un atacante podría manipular consultas para acceder o modificar información.	Compromiso de la base de datos	Crítico	Crítica	Prepared statements, ORM seguro, WAF	Implementar consultas parametrizadas y monitoreo SQL
Validación débil de roles	Existen registros de roles tipo "null" y "unknown".	RBAC, gestión de roles, BD	Escalación de privilegios y fallas de autorización	Manipulación de roles, inserción manual	Un atacante podría alterar roles y obtener privilegios indebidos.	Escalación de privilegios	Crítico	Crítica	Validación estricta de roles y restricciones en BD	Implementar RBAC robusto y control centralizado
Sistema de logs limitado y sin SIEM	Los logs no son accesibles desde el panel administrativo y requieren acceso directo a la BD.	Logs, auditoría, BD	Limitada detección y monitoreo de incidentes	Alteración de logs, eliminación de evidencias	Un atacante privilegiado podría modificar registros sin trazabilidad adecuada.	Pérdida de trazabilidad y monitoreo	Alto	Alta	SIEM, logs inmutables y alertas	Implementar SIEM centralizado y almacenamiento seguro
Ausencia de monitoreo de usuarios activos/bloqueados	El administrador no puede visualizar usuarios activos o bloqueados desde la aplicación.	Panel administrativo, gestión de usuarios	Respuesta tardía ante incidentes	Simulación de cuentas comprometidas	Una cuenta comprometida podría permanecer activa sin detección inmediata.	Persistencia de accesos maliciosos	Medio-Alto	Media-Alta	Dashboard de sesiones y bloqueo inmediato	Implementar monitoreo en tiempo real de sesiones y usuarios

6. RECOMENDACIONES GENERALES Y CONCLUSIONES ESPECIFICADA POR CASOS

Hallazgo 1 — Creación ilimitada de cuentas de clientes

Observación

El sistema permite la creación ilimitada de cuentas de clientes mediante correo y contraseña o autenticación con Google. No se observan controles anti automatización ni limitaciones de registros.

Superficie de ataque

- Registro de usuarios
- Formularios públicos
- Base de datos
- API de autenticación

Vulnerabilidad teórica

Posible abuso del sistema mediante automatización masiva de registros y agotamiento de recursos.

Pruebas hipotéticas

- Automatización de creación de cuentas
- Uso de bots
- Registro masivo mediante correos temporales
- Flood de peticiones concurrentes

Simulación de ataque

Un atacante podría automatizar la creación de miles de cuentas falsas para provocar saturación de la base de datos y degradación del servicio.

Riesgo

- Consumo excesivo de recursos
- Saturación de la base de datos
- Denegación parcial de servicio

Impacto: Alto

Severidad: Alto

Mitigación

- CAPTCHA

- Rate limiting
- Restricción de registros por IP
- Validación anti-bot

Mejora recomendada

Implementar controles anti automatización y validación de reputación de correo electrónico.

Hallazgo 2 — Ausencia de CAPTCHA en autenticación

Observación

El sistema no implementa CAPTCHA en el login pese a contar únicamente con bloqueo temporal tras 5 intentos fallidos.

Superficie de ataque

- Login
- Sistema de autenticación
- Gestión de sesiones

Vulnerabilidad teórica

Exposición a ataques de fuerza bruta y credential stuffing.

Pruebas hipotéticas

- Fuerza bruta automatizada
- Reutilización de credenciales filtradas
- Rotación de IPs
- Enumeración de usuarios

Simulación de ataque

Un atacante podría utilizar scripts automatizados para probar múltiples credenciales hasta obtener acceso válido.

Riesgo

- Acceso no autorizado
- Robo de cuentas
- Compromiso de información

Impacto: Alto

Severidad: Alta

Mitigación

- CAPTCHA adaptativo
- Rate limiting
- Detección de comportamiento automatizado
- MFA adicional

Mejora recomendada

Implementar CAPTCHA dinámico tras intentos consecutivos y monitoreo de accesos sospechosos.

Hallazgo 3 — Ausencia de validación estricta de campos en formularios

Observación

Los formularios de creación de usuarios y groomers no cuentan con validaciones estrictas visibles, permitiendo ingresar datos arbitrarios.

Superficie de ataque

- Formularios de registro
- Creación de usuarios
- Gestión administrativa

Vulnerabilidad teórica

Posible ingreso de datos inválidos, payloads maliciosos o corrupción lógica de datos.

Pruebas hipotéticas

- Inserción de caracteres especiales
- Inputs extremadamente largos
- Payloads XSS
- Datos inconsistentes

Simulación de ataque

Un atacante podría ingresar información maliciosa o inválida que afecte la integridad de la aplicación o la base de datos.

Riesgo

- Corrupción de datos
- XSS almacenado
- Inconsistencias en registros

Impacto

Medio-Alto

Severidad

Media-Alta

Mitigación

- Validaciones frontend y backend
- Sanitización de entradas
- Restricciones de longitud y formato

Mejora recomendada

Implementar validaciones estrictas basadas en esquemas tipados y sanitización centralizada.

Hallazgo 4 — Ausencia de MFA en cuentas Groomer y clientes

Observación

Las cuentas Groomer y clientes no cuentan con autenticación multifactor.

Superficie de ataque

- Login Groomer
- Login Cliente
- Gestión de sesiones

Vulnerabilidad teórica

Mayor exposición a compromiso de cuentas mediante robo de credenciales.

Pruebas hipotéticas

- Credential stuffing
- Phishing
- Robo de sesiones
- Fuerza bruta

Simulación de ataque

Un atacante que obtenga credenciales válidas podría acceder directamente a cuentas sin segunda verificación.

Riesgo

- Acceso no autorizado
- Escalación lateral
- Robo de información

Impacto: Alto

Severidad: Alta

Mitigación

- MFA obligatorio
- Verificación adicional para accesos sensibles
- Alertas de inicio sospechoso

Mejora recomendada

Implementar MFA obligatorio para Groomers y MFA opcional reforzado para clientes.

Hallazgo 5 — Bloqueo temporal insuficiente frente a automatización

Observación

El sistema bloquea accesos tras 5 intentos durante 15 minutos, pero no implementa CAPTCHA ni controles avanzados contra automatización o rotación de IP.

Superficie de ataque

- Sistema de autenticación
- Login
- Gestión de sesiones

Vulnerabilidad teórica

Posible bypass mediante distribución de ataques desde múltiples IPs.

Pruebas hipotéticas

- Rotación de IPs
- Ataques distribuidos
- Automatización paralela

Simulación de ataque

Un atacante podría utilizar múltiples direcciones IP para evitar el bloqueo temporal y continuar ataques de fuerza bruta.

Riesgo

- Compromiso de cuentas
- Persistencia de ataques automatizados

Impacto: Alto

Severidad: Alto

Mitigación

- Rate limiting global

- Fingerprinting de dispositivos
- CAPTCHA progresivo
- Monitoreo de comportamiento

Mejora recomendada

Implementar protección inteligente basada en reputación IP y análisis de comportamiento.

Hallazgo 6 — Ausencia visible de controles contra SQL Injection

Observación

No se observan mecanismos visibles relacionados con validación anti SQL Injection o filtrado de entradas.

Superficie de ataque

- Formularios
- Backend
- Base de datos

Vulnerabilidad teórica

Posible explotación mediante inyección SQL si el backend no utiliza consultas parametrizadas.

Pruebas hipotéticas

- Payloads SQL
- Bypass de autenticación
- Enumeración de tablas

Simulación de ataque

Un atacante podría intentar inyectar consultas maliciosas para acceder o modificar información de la base de datos.

Riesgo

- Robo de información
- Alteración de datos
- Compromiso total de BD

Impacto: Crítico

Severidad: Crítico

Mitigación

- Prepared statements

- ORM seguro
- Validación backend
- WAF (en producción)

Mejora recomendada

Implementar consultas parametrizadas y monitoreo de patrones SQL maliciosos.

Hallazgo 7 — Validación débil de roles en la base de datos

Observación

Se identifican registros de roles con valores “null” y “unknown”, indicando falta de validación estricta de roles.

Superficie de ataque

- RBAC
- Gestión de roles
- Base de datos

Vulnerabilidad teórica

Posibles fallas de autorización o escalación de privilegios.

Pruebas hipotéticas

- Manipulación de roles
- Inserción manual de valores inválidos
- Escalación horizontal/vertical

Simulación de ataque

Un atacante podría intentar modificar manualmente valores de rol para obtener privilegios indebidos.

Riesgo

- Escalación de privilegios
- Acceso indebido
- Fallas de autorización

Impacto: Crítico

Severidad: Crítica

Mitigación

- Enumeración estricta de roles
- Restricciones en BD

- Validación backend

Mejora recomendada

Implementar RBAC robusto con validación estricta y control centralizado de privilegios.

Hallazgo 8 — Sistema de logs limitado y sin integración SIEM

Observación

Existen tablas de logs con información de navegador, ID de usuario y rol, pero no son accesibles desde el panel administrativo y requieren acceso directo a la base de datos.

Superficie de ataque

- Logs
- Auditoría
- Base de datos

Vulnerabilidad teórica

Falta de monitoreo centralizado y limitada capacidad de detección temprana de incidentes.

Pruebas hipotéticas

- Alteración de logs
- Eliminación de evidencias
- Acceso indebido a auditorías

Simulación de ataque

Un atacante con acceso privilegiado podría modificar registros sin mecanismos visibles de integridad o monitoreo activo.

Riesgo

- Pérdida de trazabilidad
- Detección tardía de incidentes
- Encubrimiento de actividad maliciosa

Impacto: Alto

Severidad: Alto

Mitigación

- Integración SIEM
- Logs inmutables
- Alertas automáticas

- Centralización de auditoría

Mejora recomendada

Implementar SIEM con correlación de eventos y almacenamiento seguro de logs.

Hallazgo 9 — Ausencia de control visual sobre usuarios activos y bloqueados

Observación

El administrador no puede visualizar directamente usuarios activos, bloqueados o estados de acceso desde la aplicación web.

Superficie de ataque

- Panel administrativo
- Gestión de usuarios

Vulnerabilidad teórica

Limitada capacidad operativa para responder rápidamente ante incidentes de seguridad.

Pruebas hipotéticas

- Simulación de cuentas comprometidas
- Validación de bloqueo manual
- Monitoreo de sesiones activas

Simulación de ataque

Una cuenta comprometida podría permanecer activa sin que el administrador tenga visibilidad inmediata para revocar accesos.

Riesgo

- Persistencia de accesos maliciosos
- Respuesta tardía a incidentes

Impacto: Medio-Alto

Severidad: Media-Alta

Mitigación

- Dashboard de sesiones activas
- Gestión centralizada de usuarios
- Bloqueo inmediato de cuentas

Mejora recomendada

Implementar panel de monitoreo en tiempo real de usuarios, sesiones y estados

